GitOps-Driven Zero Trust Infrastructure Lab

Azure | GitHub Actions | Terraform | Ansible | Tailscale

Infrastructure as Code
Identity over Secrets
Private by Default

1 DEVELOPER & SOURCE CONTROL

Code • Review • Validate

Developer Workstation

Git Push

Local Git Repository
hybrid-infrastructure-lab

Push to GitHub

GitHub Repository
hybrid-infrastructure-lab

- Terraform infrastructure code
- Ansible playbooks and roles
- Tailscale policy.hujson
- GitHub Actions workflows
- TFLint (infrastructure linting)
- Checkov (security scanning)
- Infrastructure and security docs

Pull Request Workflow

1. Git Push
2. Pull Request
3. Automated Validation
4. Plan Review
5. Human Review and Approval
6. Merge to main

Validation Checks (GitHub Actions)

- Terraform fmt
- Terraform validate
- TFLint
- Checkov security scanning
- Ansible syntax validation
- Ansible lint
- Tailscale policy validation

2 IDENTITY FEDERATION & DEPLOYMENT CONTROL

OIDC • Least Privilege • Approved Deployments

GitHub Actions
CI/CD Orchestration

OpenID Connect (OIDC)
Workload Identity Federation
No client secrets
No long-lived keys

Microsoft Entra ID
Workload Identity Federation (OIDC)

Azure RBAC
Least-privilege access (scoped roles)

Azure Subscription

Tailscale
Policy Management (OIDC)
No long-lived auth keys

Post-Merge Deployment Approval Gate
Manual approval required before infrastructure changes are applied

Deployment Workflow (GitHub Actions)

1 Terraform Identity Foundation
- Entra ID resources
- Managed identities
- RBAC assignments
- Networking (vNet/subnets)
- Terraform state: hybrid-indentity.tfstate

2 Terraform VM Resources
- VM infrastructure (automation + workload)
- Network configuration
- NSGs and private networking
- Terraform state: hybrid-vmresource.tfstate

3 Tailscale Policy GitOps
- Deploy policy.hujson
- Update Tailscale access-control policy
- Manage tags and ACLs
- Via Tailscale API (used with OIDC)

4 Ansible Configuration Management
- Configure vm-cm-01
- Configure workload VMs
- Install and configure applications
- Enforce security baseline
- Idempotent configuration

State Management

Azure Storage Account
(for Terraform state)

- hybrid-indentity.tfstate (remote state)
- hybrid-vmresource.tfstate (remote state)

Key Principles

- OIDC / Workload Identity Federation
- Least-privilege Azure RBAC
- Separate state files
- No embedded secrets
- Approval gate before apply

3 AZURE PRIVATE INFRASTRUCTURE

Private Network • No Public IPs • Zero Trust

Azure

Resource Group
rg-hybrid-infra

vnet-hybrid-infra (10.20.0.0/16)

Automation Subnet
snet-automation (10.20.1.0/24)

vm-cm-01
10.20.1.4

Control Manager (CM)
- Ansible controller
- Azure Managed Identity
- Tailscale client
- Private SSH administration
- Configuration management

Additional CM nodes (Optional – HA)
vm-cm-02 10.20.1.5
vm-cm-03 10.20.1.6 • • •

Workload Subnet
snet-workload (10.20.2.0/24)

vm-workload-01 10.20.2.4
vm-workload-02 10.20.2.5

Workload VMs (Terraform for_each)
- Linux baseline
- Nginx reverse proxy
- Python application
- PostgreSQL
- Node Exporter

Additional workload VMs (Optional)
• • • vm-workload-n (10.20.2.x)

Access Restrictions (Enforced)

- Workload VMs have no public IP addresses
- GitHub does not SSH directly into workload VMs
- PostgreSQL is not publicly exposed
- Workload VMs cannot initiate unrestricted management access to CM

5 APPLICATION DELIVERY (FUTURE)

Public Access (Optional) • Secure by Default

Optional – Future Implementation

Internet
HTTPS (80/443 only)
Azure Public Load Balancer (Optional – Future)
Private backend pool (workload subnet)
Nginx (reverse proxy)
Python Application (sample app)
PostgreSQL (not publicly exposed)

Observability & Recovery (Future)

Monitoring • Alerting • Automated Remediation

Node Exporter (metrics from workload VMs)
Prometheus (Future)
Grafana (Future)
Alerting (Future)
Controlled Ansible Remediation (Future)
Service Recovery (Future)

4 ACCESS CONTROL & TRUST BOUNDARIES

Tailscale Private Access • Identity-Aware • Least Privilege

Authorized Administrator
Tailscale SSH (via Tailscale policy)
Tailscale Identity & Access Layer
- Access-control policy (policy.hujson)
- Authorizes human and service identities

vm-cm-01 (10.20.1.4)
Private SSH (via SSH keys)
vm-workload-01 (10.20.2.4)
vm-workload-02 (10.20.2.5)

Tailscale Policy
Controls which identities can access which devices
(e.g., admins → vm-cm-01 via Tailscale SSH)

OIDC / Workload Identity Federation
Used for platform authentication
(GitHub → Azure, GitHub → Tailscale)

SSH Keys
Used for internal configuration management
(vm-cm-01 → workload VMs)

Legend

- Code / Review Flow
- OIDC Identity Federation
- Terraform Provisioning
- Tailscale Private Access
- SSH (Internal Management)
- Application Traffic (HTTP/HTTPS)
- Monitoring / Remediation
- Azure Resource Boundary
- Network Boundary
- Future Implementation
- Security Restriction